
Web Application Security

The Goal of Security

The goal of software security is to maintain the **confidentiality, integrity,** and **availability** of information resources in order **to enable successful business operations**

This goal is accomplished through the implementation of **security controls**

The Goal of Security

Information is probably the most valuable item we now have

Malicious users are looking for ways to steal users' data and identities by sneaking into insecure applications

Security Attack Categories

Spoofing impersonating something or someone else

Tampering modifying something you're not supposed to modify

It can include packets on the wire (or wireless), bits on disk, or the bits in memory

Repudiation claiming you didn't do something

Denial of Service attacks designed to prevent a system from providing service, including by crashing it, making it unusably slow, or filling all its storage

Security Attack Categories

Information Disclosure exposing information to people who are not authorized to see it

Elevation of Privilege when a program or user is technically able to do things that they're not supposed to do

Threat Mitigation Approach

What can you do to prevent these attacks?

Threat Type	Property Violated	Mitigation Approach
Spoofing	Authentication	
Tampering	Integrity	
Repudiation	Non-repudiation	
Information Disclosure	Confidentiality	
Denial of Service	Availability	
Elevation of Privilege	Authorization	

Threat Mitigation Approach

Threat Type	Property Violated	Mitigation Approach
Spoofing	Authentication	Passwords, Multi-Factor Authentication, Digital Signature
Tampering	Integrity	Permissions/ACLs, Digital Signature
Repudiation	Non-repudiation	Secure Logging and Auditing, Digital Signature
Information Disclosure	Confidentiality	Encryption, Permissions/ACLs
Denial of Service	Availability	Quotas, Permissions/ACLs
Elevation of Privilege	Authorization	Permissions/ACLs, Input Validation

Open Web Application Security Project (OWASP)

The **Open Web Application Security Project® (OWASP)**

is a nonprofit foundation that works to improve the security of software

OWASP Foundation is the source for developers and technologists to secure the web

OWASP provides

- tools and resources

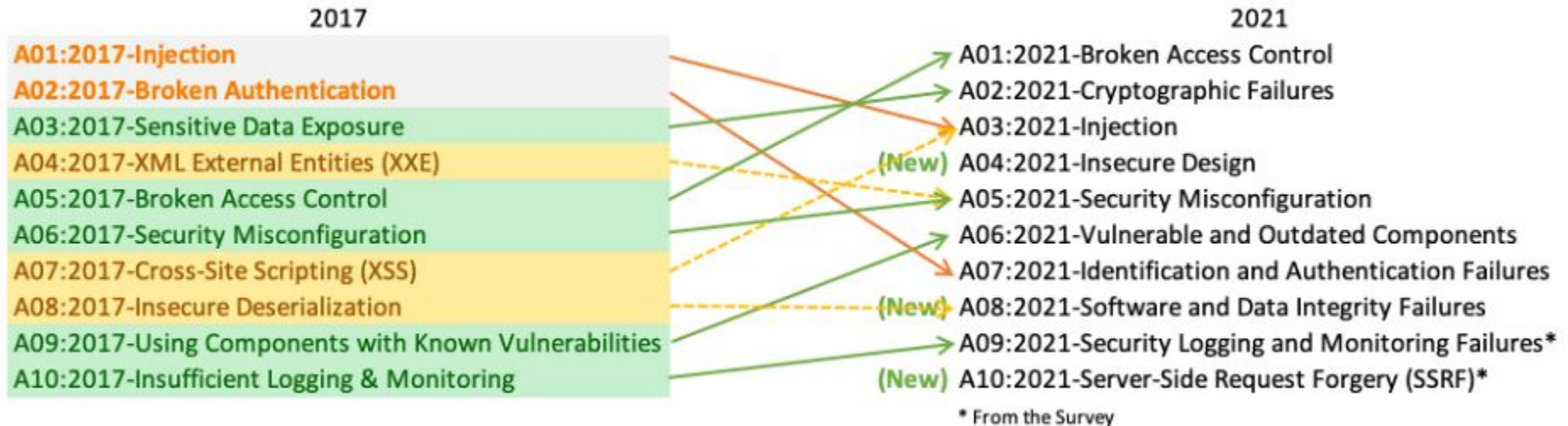
- community and networking

- education & training

Top 10 Web Application Security Risks

Comparing top 10 during 2017 and 2021

There are new risks in 2021



OWASP Secure Coding Checklist

Input Validation	Data Protection
Output Encoding	Communication Security
Authentication & Password Management	System Configuration
Session Management	Database Security
Access Control	File Management
Cryptographic Practices	Memory Management
Error Handling & Logging	

Authentication and Authorization

Authentication refers to the process of validating the identity of users, applications, or systems attempting to gain access to a resource. It seeks to answer the question, “**Who are you?**”

Authentication and Authorization

Authorization, on the other hand, is the process of determining the level of access or permissions granted to an authenticated entity

It addresses the question, “**What are you allowed to do?**” by enforcing policies that define the actions and resources accessible to users or systems

Authentication Mechanisms

Password-Based Authentication

This method requires users to provide a combination of username and password

Despite its widespread use, it is **susceptible to attacks such as brute force, phishing, and credential stuffing**

Authentication Mechanisms

Multi-Factor Authentication (MFA)

MFA enhances security by requiring users to present multiple pieces of evidence (factors) for authentication such as:

Something you know – Password or PIN

Something you have – One-time passcode (OTP), security key

Something you are – Biometric identifiers (fingerprints, facial recognition)

Authentication Mechanisms

OAuth 2.0 (Authorization Framework with Authentication Extensions)

OAuth 2.0 enables delegated access by allowing third-party applications to obtain limited access to user accounts on an HTTP service

While originally designed for **authorization**, extensions such as OIDC enable its use for authentication

Authentication Mechanisms

OAuth 2.0 (Authorization Framework with Authentication Extensions)

Access tokens and refresh tokens govern resource access without exposing user credentials

Authentication Mechanisms

OpenID Connect (OIDC)

An identity layer built on top of OAuth 2.0, OIDC facilitates single sign-on (SSO) by allowing users to authenticate via trusted identity providers (IdPs) such as Google, Microsoft, or Apple

Utilizes JSON Web Tokens (JWT) to convey user identity and attributes between parties

Authentication Mechanisms

Security Assertion Markup Language (SAML)

SAML 2.0 is an XML-based framework facilitating SSO for enterprise applications

It allows identity providers to exchange authentication and authorization data with service providers

Authentication Mechanisms

Biometric Authentication

Involves the use of physical characteristics (e.g., facial recognition, retina scans) for identity verification

Authorization Mechanisms

Role-Based Access Control (RBAC)

RBAC restricts system access based on predefined roles assigned to users

Roles aggregate permissions, allowing for simplified management

Authorization Mechanisms

Attribute-Based Access Control (ABAC)

ABAC evaluates access requests against policies that consider user attributes (e.g., department, clearance level), resource characteristics, and contextual information

Authorization Mechanisms

OAuth Scopes and Resource Servers

OAuth scopes define the extent of access granted to a client application

Each scope corresponds to specific API endpoints or resources

Authorization Mechanisms

Access Control Lists (ACLs)

ACLs specify explicit permissions for individual users or groups concerning particular resources

Authorization Mechanisms

Policy-Based Access Control (PBAC)

PBAC applies policies that dynamically enforce access control rules based on contextual data and business logic

Further References

https://www.owasp.org/index.php/OWASP_Guide_Project

https://www.owasp.org/index.php/Category:OWASP_Code_Review_Project

https://www.owasp.org/index.php/OWASP_Secure_Coding_Practices_-_Quick_Reference_Guide

https://www.owasp.org/images/b/ba/Web_Application_Development_Dos_and_Donts.ppt